تقرير مراجعة وتدقيق

منصة محمد بن عبد الوهاب الثانوية للبنين

الملاحظات الفنية والتقنية والأمنية والتشغيلية
واقتراحات التعديل

نطاق المراجعة: النسخة التجريبية المنشورة على رابط Claude Artifact

تاريخ المراجعة: 4 نوفمبر 2026

الإصدار: 1.0

1. الملخص التنفيذي

المنصة حالياً **واجهة أولية (نموذج) فقط**، ولا يوجد خلفها خادم أو قاعدة بيانات. جودة الواجهة جيدة، وتنظيم الكود يسمح بربطه لاحقاً بنظام حقيقي. أهم ما يحتاج إلى معالجة فورية هو أن الصفحة منشورة **على رابط عام، وتحمل الشعار الرسمي للوزارة، وفيها نموذج لكلمة المرور**. هذا قد يجعلها تبدو كصفحة تصيّد، أو يدفع أحد المستخدمين إلى كتابة كلمة مروره الحقيقية فيها.

المحور	التقييم	التعليق
جودة الواجهة كنموذج أولي	جيد جداً	عربية من اليمين لليسار بشكل صحيح، متجاوبة، فيها عناصر إتاحة جيدة، وهوية بصرية متسقة
الجاهزية التقنية للإنتاج	10%	واجهة فقط، بلا خادم ولا بيانات حقيقية
الأمان بوضعه الحالي	مقبول بشروط	لا يجمع أي بيانات، لكن مخاطرة الشعار والرابط العام قائمة (S1)
الجاهزية التشغيلية	غير جاهز	لا نسخ احتياطي، ولا مراقبة، ولا بيئات، ولا تحكم بالإصدارات

> **عدد الملاحظات:** 11 ملاحظة أمنية وفنية (3 عالية الخطورة، و4 متوسطة، و4 منخفضة)، إضافة إلى 6 بنود تشغيلية.

2. الوضع الحالي للنظام

الرئيسية ← اختيار الهيئة (3) ← اختيار الدور (11) ← تسجيل الدخول (تجريبي)

البند	الوصف
التقنيات	React 19.2.8 وTailwind CSS 4، والتنقل بالروابط من نوع `#/section/…` و`#/login/…`
البيانات	بيانات وهمية مكتوبة داخل الكود، وهي قائمة الهيئات والأدوار فقط
تسجيل الدخول	النموذج لا يرسل أي شيء ولا يحفظه، ويعرض رسالة "لم يتم تسجيل أي دخول"
الشبكة والتخزين	لا يوجد أي اتصال بالشبكة، ولا تخزين في المتصفح، ولا صلاحيات تشغيل
الحجم	حوالي 410KB، منها حوالي 17KB منطق التطبيق، وحوالي 97KB صورة الشعار المضمّنة

الهيئات والأدوار المعرّفة

الهيئة	الأدوار
الهيئة الأكاديمية	المنسق، المعلم
الهيئة الإدارية	منسق شؤون الطلاب، المشرف الإداري، الاختصاصي النفسي*، الاختصاصي الاجتماعي*، الممرض*، موظف الاستقبال
إدارة النظام	مدير المدرسة، نائب المدير للشؤون الأكاديمية، مدير النظام

* أدوار عليها شارة "سجلات مقيّدة حسب الاختصاص"

3. الملاحظات الأمنية

S1 عالية — الشعار الرسمي واسم المدرسة على رابط عام فيه نموذج كلمة مرور

الوصف: الصفحة تعرض شعار وزارة التربية والتعليم والتعليم العالي، واسم المدرسة، ونموذج دخول بكلمة مرور، وكل ذلك على رابط عام.

الأثر: قد تُصنَّف الصفحة كمحاولة تصيّد أو انتحال صفة جهة رسمية، وقد يكتب فيها مستخدم بيانات دخوله الحقيقية.

التوصية:

- أخذ موافقة مكتوبة من إدارة المدرسة أو الوزارة على استخدام الشعار والاسم.
- جعل الرابط خاصاً، ومشاركته فقط مع الفريق المعني.
- استبدال حقلي اسم المستخدم وكلمة المرور في النسخة التجريبية بزر "دخول تجريبي" (انظر التعديل 6.1).

S2 عالية (في التصميم) — المستخدم يختار دوره بنفسه قبل تسجيل الدخول

الوصف: الدور يُختار من الواجهة، ويظهر في الرابط مثل `#/login/system-admin`.

الأثر: إذا بُني النظام الحقيقي على هذا المنطق، يستطيع أي مستخدم أن يطلب صلاحيات أعلى من صلاحياته بتغيير الرابط.

التوصية: شاشة دخول واحدة، والخادم هو من يحدد دور المستخدم من حسابه. لا يُعتمد أبداً على أي قيمة للدور تأتي من المتصفح. يمكن الإبقاء على شاشات الهيئات والأدوار كصفحات تعريفية فقط، أو حذفها (انظر التعديل 6.2).

S3 عالية (في التصميم) — تقييد السجلات الحساسة موجود كنص للعرض فقط

الوصف: شارة "سجلات مقيّدة" على أدوار الاختصاصي النفسي والاختصاصي الاجتماعي والممرض مجرد علامة في الواجهة.

الأثر: السجلات النفسية والصحية لطلاب قاصرين من أكثر البيانات حساسية، وأي تسرب لها له أثر قانوني وأخلاقي كبير.

التوصية: تطبيق التقييد في الخادم على مستوى السجل والحقل، وعزل هذه السجلات حتى عن مدير النظام، وتسجيل كل عملية اطلاع عليها في سجل النشاطات.

S4 متوسطة — غياب متطلبات الهوية والتحقق في التصميم

التوصية:

- دخول موحد (SSO) عبر الحساب الذي تستخدمه المدرسة، مثل Microsoft 365، بدلاً من كلمات مرور خاصة بالمنصة.
- التحقق الثنائي (MFA) إلزامي لمدير النظام والإدارة والأدوار المقيّدة.
- تحديد عدد محاولات الدخول، وإنهاء الجلسة تلقائياً بعد فترة خمول.

S5 متوسطة الامتثال لقانون حماية البيانات الشخصية

الوصف: النظام الحقيقي سيعالج بيانات شخصية لطلاب قاصرين، منها بيانات صحية ونفسية.

التوصية:

- الالتزام بقانون حماية خصوصية البيانات الشخصية القطري رقم 13 لسنة 2016.
- الالتزام بسياسات الوزارة بشأن مكان استضافة البيانات.
- تشفير البيانات أثناء النقل وأثناء التخزين.
- وضع سياسة للاحتفاظ بالبيانات وحذفها.

S6 منخفضة الهيكل الإداري ظاهر للعموم قبل تسجيل الدخول

التوصية: هذا مقبول في النسخة التجريبية، لكن يُفضّل في الإنتاج إخفاء قائمة الأدوار حتى يسجل المستخدم دخوله.

4. الملاحظات الفنية والتقنية

T1 متوسطة دالة تحميل البيانات لا تعالج الأخطاء

الوصف: إذا فشل طلب البيانات تبقى الشاشة على "جارٍ التحميل..." إلى ما لا نهاية، ولا يوجد Error Boundary يلتقط أعطال الواجهة.

التوصية: إضافة حالة خطأ مع زر لإعادة المحاولة، وإضافة Error Boundary (انظر التعديل 6.3).

T2 منخفضة الخط الأساسي غير متوفر في أغلب الأجهزة

الوصف: خط "Sakkal Majalla" موجود في ويندوز فقط، لذلك يتغير الخط في أندرويد وآيفون وماك.

التوصية: تحميل خط Noto Naskh Arabic أو Noto Kufi Arabic من Google Fonts.

T3 منخفضة صورة الشعار مضمّنة بحجم كبير

الوصف: الشعار صورة PNG حجمها حوالي 97KB مضمّنة داخل الملف، وهذا يبطئ التحميل الأول.

التوصية: تحويله إلى SVG أو WebP مضغوط، وسيقل حجمه غالباً إلى أقل من 15KB.

T4 منخفضة شريط العنوان فارغ في الرئيسية على الجوال

الوصف: في الصفحة الرئيسية يُخفى الشعار، واسم المنصة مخفي على الشاشات الصغيرة (`hidden sm:block`)، فيبقى في الشريط زر بلا محتوى ظاهر.

التوصية: إظهار اسم مختصر على الجوال، مثل "منصة ابن عبد الوهاب".

T5 متوسطة الكود المصدري غير موجود في مستودع Git

الأثر: لا يوجد تتبع للتغييرات، ولا مراجعة للكود، ولا نسخة احتياطية منه، ولا يمكن إعادة البناء.

التوصية: نقل الكود إلى مستودع Git، مع ملف README، وخطوات للبناء والنشر، ومراجعة إلزامية قبل الدمج.

5. الملاحظات التشغيلية

#	البند	الحالة	التوصية
O1	خادم وقاعدة بيانات	غير موجود	بناء واجهة API تطبّق الصلاحيات، وقاعدة بيانات مشفرة
O2	الاستضافة	غير مناسبة	صفحات Claude Artifact مناسبة للعرض فقط، وليست مكاناً لاستضافة بيانات الطلاب. يلزم استضافة مستقلة معتمدة تديرها المدرسة
O3	النسخ الاحتياطي والاستعادة	غير موجود	نسخ احتياطي يومي مشفر، واختبار الاستعادة كل ربع سنة
O4	المراقبة والتنبيهات	غير موجود	مراقبة توفر الخدمة، وسجلات الأخطاء، وتنبيهات لمحاولات الدخول المشبوهة
O5	البيئات المنفصلة	غير موجود	بيئات منفصلة للتطوير والاختبار والإنتاج، وبيانات وهمية فقط خارج الإنتاج
O6	وضوح أنها نسخة تجريبية	متوفر ✓	الإبقاء على التنبيه في التذييل وفي شاشة الدخول

6. اقتراحات التعديل على الكود

6.1 استبدال نموذج كلمة المرور بدخول تجريبي (يعالج S1)

```
// LoginPage — demo mode: no username/password fields
<div role="note" className="...">
  نسخة تجريبية للعرض فقط — لا تُدخل أي بيانات حقيقية.
</div>
<button onClick={() => navigate(`/demo/${role.id}`)} className="...">
  دخول تجريبي بصفة {role.title}
</button>
```

6.2 تحديد الدور من الخادم وليس من الرابط (يعالج S2 وS3)

```
// Client: one login entry point, role comes from the server session
const session = await api.get("/auth/me");   // { user, roles: ["teacher"], scopes: {...} }

// Server (example, Express): enforce on EVERY request
function requireRole(...allowed) {
  return (req, res, next) =>
    req.user && req.user.roles.some(r => allowed.includes(r))
      ? next() : res.status(403).end();
}
app.get("/api/counseling/:studentId",
  requireRole("psychologist", "social-worker"),
  auditRead("counseling"),          // log every read of restricted records
  getCounselingRecord);
```

6.3 معالجة الأخطاء في تحميل البيانات (يعالج T1)

```
function useAsync(fn, deps) {
  const [state, setState] = useState({ data: undefined, loading: true, error: null });
  useEffect(() => {
    let alive = true;
    setState(s => ({ ...s, loading: true, error: null }));
    fn().then(
      data  => alive && setState({ data, loading: false, error: null }),
      error => alive && setState({ data: undefined, loading: false, error })
    );
    return () => { alive = false; };
  }, deps);
  return state;
}
// In the page:
if (error) return <p role="alert">تعذّر تحميل البيانات. <button onClick={retry}>إعادة
المحاولة</button></p>;
```

6.4 تحميل الخط العربي (يعالج T2)

```
<link rel="stylesheet"
  href="https://fonts.googleapis.com/css2?family=Noto+Naskh+Arabic:wght@400;700&display=swap">
--font-sans: "Noto Naskh Arabic", "Sakkal Majalla", Tahoma, sans-serif;
```

6.5 اسم مختصر في الشريط على الجوال (يعالج T4)

```
<span className="sm:hidden text-base font-bold">منصة ابن عبد الوهاب</span>
<span className="hidden sm:block text-lg sm:text-xl font-bold">{fullName}</span>
```

7. مصفوفة صلاحيات مقترحة (مبدئية)

تحتاج المصفوفة إلى اعتماد من إدارة المدرسة. الرموز: ق = قراءة، ت = تعديل، — = لا صلاحية. "مسند" تعني الصفوف أو المواد المسندة للمستخدم فقط.

الدور	الدرجات	الغياب والتأخر	السلوك	السجل النفسي والاجتماعي	السجل الصحي	الحسابات
المعلم	ق/ت (مسند)	ق/ت (مسند)	ت (مسند)	—	—	—
المنسق	ق (المادة)	ق (المادة)	ق	—	—	—
منسق شؤون الطلاب	ق	ق/ت	ق/ت	إحالة فقط	—	—
المشرف الإداري	—	ق/ت (الشعب)	ق/ت	إحالة فقط	—	—
الاختصاصي النفسي	ق	ق	ق	ق/ت (حالاته)	—	—
الاختصاصي الاجتماعي	ق	ق	ق	ق/ت (حالاته)	—	—

الدور	الدرجات	الغياب والتأخر	السلوك	السجل النفسي والاجتماعي	السجل الصحي	الحسابات
الممرض	—	ق	—	—	ق/ت	—
موظف الاستقبال	—	تسجيل الخروج	—	—	—	—
مدير المدرسة	ق	ق	ق	ملخص فقط	ملخص فقط	—
نائب المدير الأكاديمي	ق/اعتماد	ق	ق	—	—	—
مدير النظام	—	—	—	—	—	ق/ت + سجل النشاطات

8. خطة التنفيذ حسب الأولوية

فوراً
خلال أسبوع

- جعل الرابط خاصاً، أو أخذ موافقة مكتوبة على استخدام الشعار والاسم (S1).
- استبدال حقل كلمة المرور بزر دخول تجريبي (6.1).

المرحلة 1
2 إلى 3 أسابيع

- نقل الكود إلى Git (T5).
- اعتماد مصفوفة الصلاحيات (القسم 7).
- إصلاح الملاحظات من T1 إلى T4.

المرحلة 2
6 إلى 10 أسابيع

- بناء الخادم وقاعدة البيانات المشفرة.
- الدخول الموحد مع التحقق الثنائي (S4).
- تطبيق الصلاحيات في الخادم (S2 وS3).
- سجل نشاطات غير قابل للتعديل.

قبل الإطلاق

- مراجعة الامتثال لقانون الخصوصية (S5).
- اختبار اختراق مستقل.
- تجهيز الاستضافة والنسخ الاحتياطي والمراقبة (O1 إلى O5).
- تجربة محدودة مع عينة من المستخدمين.

ملاحظة: هذه المراجعة مبنية على النسخة المنشورة وعلى الكود المجمّع داخلها، كما كانت في تاريخ المراجعة. لا يوجد خادم أو قاعدة بيانات لمراجعتهما. المدد الزمنية في خطة التنفيذ تقديرية، وتعتمد على حجم الفريق.